



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Incidentes de Ciberseguridad

TEMA 4

Implantación de Medidas de Ciberseguridad.
Alberto Diéguez Álvarez

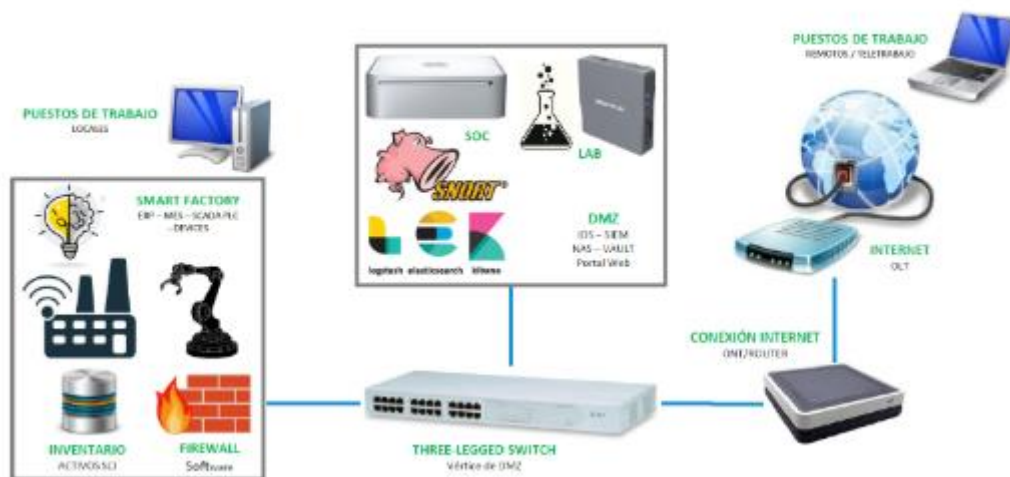
Contenido

Introducción: Estructura de la Organización Empresarial.	3
Apartado 1: Manifestación y detección del incidente.	4
Apartado 2: Definir los roles de las personas y formación del equipo de respuesta.	5
Apartado 3: Concreción del incidente.	5
Apartado 4: Medidas de actuación ante diferentes tipos de incidentes.	5
Apartado 5: Proceso de revisión, documentación y mejora.	5
Plan de actuación ante incidentes de Ciberseguridad	6
Introducción y estructura de la empresa.	6
Manifestación y detención del incidente	7
Identificación de un incidente	7
Recopilación de evidencias	7
Evaluación inicial	8
Roles y equipo de respuesta a incidentes	8
Funciones por rol	8
Miembros de alta prioridad informados	9
Llamada a filas	9
Concreción del incidente	9
Preguntas a realizar	9
Personal a informar	10
Medidas de actuación ante diferentes tipos de incidentes	10
Contención	10
Mitigación	10
Eliminación de incidentes	11
Playbook específico: Phishing	11
Proceso de revisión, documentación y mejora.	22
Cierre del incidente	23
Documentación asociada	23
Aprendizaje adquirido	23
Proceso de mejora	24
Traslado de información	24
NOTAS	25
Webgrafía	25

¿Qué te pedimos que hagas?

Introducción: Estructura de la Organización Empresarial.

Dada una empresa como la descrita en la tarea de la unidad de trabajo 1 en la que se sigue el siguiente diagrama de bloques:



Además, esta empresa sigue la siguiente estructura organizativa:



La determinación de la Estructura de la Empresa Ficticia nos permitirá identificar sus áreas de trabajo y las misiones de las mismas, con objeto de saber a qué equipos hay que involucrar en cada momento y cuándo se les debe informar acerca de los incidentes:

- CEO (Chief Executive Officer): Presidente. Gestión y Dirección administrativa.
- COO (Chief Operating Officer): Director de Operaciones.
- CFO (Chief Financial Officer): Director de Gestión Financiera.

- CMO (Chief Marketing Officer): Director de Actividades Comerciales y de Marketing.
- CIO (Chief Information Officer): Director de Sistemas de Información y Desarrollo de Aplicaciones.
- CTO (Chief Technology Officer): Director de Tecnología y Estrategia Tecnológica.
- CSO (Chief Security Officer): Responsable de Planificación y Estrategia de Seguridad.
- CISO (Chief Information Security Officer): Responsable de Ciberseguridad.
- CLO (Chief Legal Officer): Responsable del Departamento Jurídico. Es clave para la ciberseguridad.
- CDO (Chief Design Officer): Responsable de Diseño.

Con esta información proporcionada se tiene una idea general de la estructura de la empresa. El grupo de trabajadores de cada departamento y la inclusión de otros posibles departamentos queda a libre elección del alumno.

A continuación, se desglosan en apartados el desarrollo general de un Plan de Actuación ante Incidentes de Ciberseguridad. En este Plan de Actuación no se solicitan detalles a bajo nivel de herramientas a usar, solamente una **guía de actuación general**.

**Nota:* Se debe realizar un único documento con los apartados, pero no en formato pregunta respuesta, sino como un documento de “Plan de Actuación ante incidentes” desarrollado para esta empresa.

Aunque los recursos adicionales propuestos para consulta y ayuda son documentos de una extensión considerable, este documento no necesita una elevada extensión. La extensión puede estar comprendida entre 7 y 14 páginas contando portada e índice. Esta es una orientación, se pueden realizar entregas de otras extensiones.

Apartado 1: Manifestación y detección del incidente.

Deberás efectuar la siguiente tarea:

- **Describir procesos para identificación, recopilación de evidencias y evaluación inicial de incidentes.**

Apartado 2: Definir los roles de las personas y formación del equipo de respuesta.

Deberás efectuar la siguiente tarea:

- **Definir que funciones tendrá asignadas cada rol definido en caso de un incidente. Llamada a filas del equipo en caso de incidente.**
- **Indicar los miembros de alta prioridad a los que se les trasladará información preliminar.**

Apartado 3: Concreción del incidente.

Deberás efectuar la siguiente tarea:

- **Indicar principales pasos o preguntas a realizar para detectar de forma más concreta el tipo de incidente que puede estar sucediendo.**
- **Personal de empresa a los que informar.**

Apartado 4: Medidas de actuación ante diferentes tipos de incidentes.

Deberás efectuar la siguiente tarea:

- a. **Descripción general de las fases de contención, mitigación, o eliminación de los incidentes.**
- b. **Describir de forma concreta estas fases para un tipo específico de incidente (Playbook). Los tipos a elegir son: infección por gusanos, phishing, malware en Windows, DDOS y ransomware.**

Apartado 5: Proceso de revisión, documentación y mejora.

Deberás efectuar la siguiente tarea:

- **Definir el proceso de cierre de la incidencia, la documentación asociada, el aprendizaje adquirido y proceso de mejora.**
- **Traslado de información a las personas o entidades necesarias.**

Plan de actuación ante incidentes de Ciberseguridad

Autor: Alberto Diéguez Álvarez

Empresa: Invent

Versión: 1.0

Fecha: 30/01/2026

Introducción y estructura de la empresa.

Empresa Invent es una organización con actividad tecnológica y comercial. La protección contra incidentes de ciberseguridad es fundamental para la continuidad del negocio y el cumplimiento normativo garantiza la confianza de los clientes.

La estructura organizativa de la empresa Invent es la siguiente:

- CEO (Chief Executive Officer): Presidente. Gestión y Dirección administrativa.
 - COO (Chief Operating Officer): Director de Operaciones.
 - CFO (Chief Financial Officer): Director de Gestión Financiera.
 - CMO (Chief Marketing Officer): Director de Actividades Comerciales y de Marketing.
 - CIO (Chief Information Officer): Director de Sistemas de Información y Desarrollo de Aplicaciones.
 - CTO (Chief Technology Officer): Director de Tecnología y Estrategia Tecnológica.
 - CSO (Chief Security Officer): Responsable de Planificación y Estrategia de Seguridad.
 - CISO (Chief Information Security Officer): Responsable de Ciberseguridad.
 - CLO (Chief Legal Officer): Responsable del Departamento Jurídico. Es clave para la ciberseguridad.
 - CDO (Chief Design Officer): Responsable de Diseño.
-

Manifestación y detención del incidente

La detención de incidentes es clave para reducir su impacto. Podemos detectar un incidente de forma activa o pasiva.

- ❖ **Activa:** Detección de un ataque directamente.
- ❖ **Pasiva:** Detección por comportamientos extraños.

Identificación de un incidente

Se identificarán todos los activos afectados para reducir el impacto del incidente. Se deberá identificar los daños para determinar el alcance del incidente y poder tomar acciones para detener la incidencia.

- ❖ Detección de anomalías en los sistemas, redes o en aplicaciones.
- ❖ Avisos de anomalías por parte de usuarios, proveedores...
- ❖ Alertas automáticas de sistemas de seguridad.

Para la identificación de una incidencia se deberán implementar varios tipos de soluciones para su detección. Entre ellas, por ejemplo:

- ❖ **Monitorización:** Implementar sistemas de monitorización como antivirus IDS/SIEM...
- ❖ **Notificaciones de incidentes:** Disponer de canales apropiados para la comunicación de las incidencias, implementando un plan de actuación para su notificación.

Recopilación de evidencias

Una vez se ha detectado un incidente o un posible incidente, se debe recopilar todas las evidencias posibles. Con este proceso logramos entender que es lo que ha ocurrido y que activos han sido afectados.

Para la recopilación de evidencias se cumplirá con los siguientes puntos:

- ❖ Identificar los activos afectados.
- ❖ Recopilar logs de los sistemas, redes...
- ❖ Tener un registro minucioso de datos de fechas, personas...
- ❖ Automatizar el análisis de logs con herramientas específicas para ello.

Evaluación inicial

Después de realizar la recopilación de evidencias, se procede a la evaluación inicial del incidente para determinar su causa y su alcance. En esta fase se determina el impacto de la incidencia.

Para esta evaluación se determinarán los siguientes puntos:

- ❖ Clasificar el tipo de incidente.
- ❖ Evaluación de la incidencia sobre la economía, reputación, funcionamiento... de la empresa.
- ❖ Establecer un nivel al impacto (leve, moderado, crítico...).
- ❖ Activar el equipo de respuesta a incidentes.

Roles y equipo de respuesta a incidentes

Como se especifica en la estructura organizativa de la empresa en el primer apartado hay que determinar el responsable del equipo de respuesta.

El **Equipo de Respuesta a Incidentes** estará liderado por el **CISO (Chief Information Security Officer): Responsable de Ciberseguridad**. El rol del CISO es liderar y coordinar las acciones del Equipo de Respuesta a Incidentes.

Funciones por rol

Las funciones por rol quedarían asignadas de la siguiente manera:

- ❖ **CISO:** Coordinación general, toma de decisiones y reporte a dirección.
- ❖ **CIO:** Análisis técnico y recuperación de sistemas.
- ❖ **CTO:** Contención técnica y evaluación de riesgos tecnológicos.
- ❖ **CSO:** Coordinación de seguridad global y apoyo estratégico.
- ❖ **CLO:** Evaluación legal, notificaciones obligatorias y asesoramiento normativo.
- ❖ **COO:** Continuidad operativa. Ejecuta la estrategia definida.
- ❖ **CMO:** Comunicación externa controlada.

Miembros de alta prioridad informados

Los miembros de alta prioridad a los que se le trasladará la información por parte del Equipo de Respuesta a Incidentes son:

- ❖ CEO (Chief Executive Officer): Presidente. Gestión y Dirección administrativa.
- ❖ COO (Chief Operating Officer): Director de Operaciones.
- ❖ CFO (Chief Financial Officer): Director de Gestión Financiera.
- ❖ CLO (Chief Legal Officer): Responsable del Departamento Jurídico. Es clave para la ciberseguridad.

A estos miembros se le informará del tipo de incidente, el impacto, las acciones y la evolución del incidente.

Llamada a filas

El responsable del Equipo de Respuesta a Incidentes, que es el **CISO**, determina la activación de la llamada a filas y el nivel del incidente.

Para este punto se utilizan varios canales para su notificación: Teléfono, email y otras herramientas de mensajería.

Concreción del incidente

Para la corrección del incidente, se realizarán los siguientes pasos:

Recopilar información sobre el incidente, por ejemplo: Resivar logs, analizar que ha pasado y como ha pasado...

Preguntas a realizar

- ❖ ¿Qué sistemas o servicios están afectados?
- ❖ ¿Cuándo se detectó el incidente?
- ❖ ¿Existe propagación activa?
- ❖ ¿Hay pérdida o cifrado de datos?
- ❖ ¿Qué medidas se han tomado?
- ❖ ¿Existen indicios de acceso no autorizado?

Personal a informar

Dependiendo del incidente se informará a todas las partes que puedan estar involucradas o que deban ser informadas.

- ❖ Equipo de Respuesta a Incidentes: Serán los primeros en ser informados, ya que es su responsabilidad. Iniciarán la investigación.
- ❖ Dirección según impacto: Dependiendo de la incidencia, se informará al responsable.
- ❖ Usuarios afectados: Serán informados para proteger datos.
- ❖ Terceros o autoridades si aplica: Serán informados si el incidente incurre en delito.

Medidas de actuación ante diferentes tipos de incidentes

Según el tipo de incidente, se prioriza la recuperación y minimizar el impacto. Cada actuación determina responsables, medidas...

Contención

En este punto el objetivo es evitar la propagación, recopilar evidencias de la incidencia... Resumiendo, los siguientes puntos entre otros:

- ❖ Aislar los sistemas afectados
- ❖ Evitar la propagación
- ❖ Conservar las evidencias

Mitigación

En este punto el objetivo es reducir al mínimo el impacto. Para ello se citan los siguientes puntos:

- ❖ Reducir el impacto operativo.
- ❖ Aplicar medidas temporales de seguridad.
- ❖ Informar sobre el incidente a los usuarios y a todas las partes involucradas.

Eliminación de incidentes

En este punto el objetivo es eliminar la incidencia y prevenir que vuelva a ocurrir. Para ello se citan los siguientes puntos:

- ❖ Eliminar la causa de la incidencia.
- ❖ Restaurar sistemas de forma segura.
- ❖ Análisis del incidente para evitar que vuelva a suceder el mismo incidente y mejorar el todo el proceso en futuros incidentes.

Playbook específico: Phising

Investigar, remediar (contener, erradicar), ¡y comunicar en paralelo!

Asigne pasos a individuos o equipos para que trabajen simultáneamente, cuando sea posible; este playbook no es puramente secuencial. Utilice su mejor criterio.

Investigar

1. **Ámbito del ataque** Normalmente se le notificará que se está produciendo un posible ataque de phishing, ya sea por parte de un usuario, cliente o socio.
 - Determinar el **número total de usuarios afectados**.
 - Comprender **las acciones de los usuarios** en la respuesta al phishing de un correo electrónico (e.j., ¿Descargarán el archivo adjunto?, ¿Visitarán el sitio suplantado?, ¿O, dieron alguna información personal o comercial como credenciales?)
 - Encontrar la actividad potencialmente relacionada. Comprueba:
 - redes sociales
 - cualquier correo electrónico sospechoso posible.
 - correos electrónicos con enlaces a URL's externas y desconocidas.
 - correos electrónicos de no-retorno o no-entregables.
 - cualquier tipo de notificación de actividad sospechosa.

2. **Analizar el mensaje** utilizando un dispositivo seguro (es decir, **no** abrir los mensajes en un dispositivo con acceso a datos sensibles o credenciales ya que el mensaje puede contener malware), determinar:
 - quién ha recibido el mensaje
 - quién era el objetivo del mensaje (puede ser diferente de los destinatarios a los que iba realmente dirigido el mensaje)
 - dirección de correo electrónico del remitente
 - línea de asunto
 - cuerpo del mensaje
 - adjuntos (**no abra los archivos adjuntos** salvo según los procedimientos establecidos)
 - enlaces, dominios, y nombres de host (**no siga los enlaces**, excepto según los procedimientos establecidos)
 - Metadatos del correo electrónico incluidas las cabeceras de los mensajes (véase más adelante)
 - información del remitente en el campo "de" y en la cabecera del usuario autenticado-X
 - todas las direcciones IP del cliente y del servidor de correo
 - Anotar las "peculiaridades" o características sospechosas
3. **Analizar los enlaces y los archivos adjuntos**
 - utilizar la recopilación pasiva como nslookup y whois para encontrar direcciones IP e información de registro
 - encontrar dominios relacionados utilizando OSINT (e.j., [reverse whois](#)) en direcciones de correo electrónico y otros datos de registro.
 - enviar enlaces, archivos adjuntos y/o hashes a [VirusTotal](#)
 - enviar enlaces, adjuntos y/o hashes a un sandbox de malware como [Cuckoo](#), [Hybrid Analysis](#), [Joe Sandbox](#), o [VMray](#).
4. **Determine la gravedad.** Considerar:
 - si la seguridad pública o personal está en riesgo
 - si los datos personales (u otros datos sensibles) están en riesgo
 - si hay pruebas de quién está detrás del ataque
 - número de activos afectados
 - el impacto preliminar en el negocio

- si los servicios se ven afectados
 - si se pueden controlar/registrar los sistemas críticos
5. **Confirmar el alcance del incidente:**
- ¿Cuántos usuarios recibieron el correo?
 - ¿Alguno interactuó con enlaces, archivos adjuntos o proporcionó credenciales?
 - ¿Se han detectado patrones similares en otros mensajes recientes?
6. **Recolectar evidencia** de forma segura:
- No abrir enlaces ni adjuntos en sistemas con datos sensibles.
 - Guardar copias del mensaje, cabeceras y metadatos.
 - Documentar remitente, destinatarios, asunto, cuerpo, adjuntos y enlaces.
7. **Analizar** la infraestructura del ataque:
- Utilizar herramientas OSINT como whois, nslookup o reverse whois para investigar dominios y direcciones IP.
 - Comprobar actividad sospechosa en redes sociales y correos similares.
 - Enviar hashes de archivos o enlaces a servicios de análisis de malware (VirusTotal, Cuckoo, Hybrid Analysis).
8. **Clasificación y priorización:**
- Determinar tipo de phishing (credential harvesting, spear phishing, malware, etc.).
 - Evaluar gravedad según datos comprometidos, número de afectados e impacto en servicios críticos.
 - Identificar posibles autores o campañas conocidas asociadas.
9. **Preguntas clave** a usuarios afectados:
- ¿Qué acciones realizaste tras recibir el mensaje?
 - ¿Se compartió información sensible o credenciales?
 - ¿Qué dispositivos y redes estabas usando al recibir el correo?
10. **Documentación y correlación:**
- Registrar todos los hallazgos en el sistema de gestión de incidentes.
 - Correlacionar con otros eventos de seguridad o alertas recientes.
 - Preparar la información para la fase de remediación y comunicación.

Remediar

- **Planificar eventos de remediación** en los que estos pasos se pongan en marcha juntos (o de forma coordinada), con los equipos adecuados listos para responder a cualquier interrupción.
- **Considere el momento y las compensaciones** de las acciones de remediación: su respuesta tiene consecuencias.

Contención

- Contener las cuentas afectadas
 - cambiar las credenciales de acceso: Herramientas: Active Directory, Okta, Azure AD, Google Workspace Admin.
 - reducir el acceso a los servicios, sistemas o datos críticos hasta que se complete la investigación: Aplicar políticas de mínimo privilegio temporalmente.
 - reforzar la autenticación multifactor (MFA): Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
- Bloquear la actividad en función de los indicadores de compromiso descubiertos, *e.j.*:
 - bloquear dominios maliciosos mediante DNS, cortafuegos o proxies: Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
 - bloquear los mensajes con remitentes, cuerpos de mensajes, asuntos, enlaces, archivos adjuntos similares, etc., utilizando la puerta de enlace predeterminada o el servicio de correo electrónico: Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
- Implementar la retención forense o conservar copias forenses de los mensajes. Exportar mensajes a repositorio seguro manteniendo integridad con hash y registro de evidencias. Herramientas: EnCase, FTK, MailStore, Exchange eDiscovery.
- Purgar los mensajes relacionados de las bandejas de entrada de otros usuarios, o hacerlos inaccesibles de otro modo. Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
- Contener el compromiso más amplio de acuerdo con el plan general de IR. Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
- Considerar medidas de contención de los dispositivos móviles, como el borrado a través de la gestión de dispositivos móviles (MDM). Equilibrio con el impacto de la investigación/forense. Herramientas: Microsoft Authenticator, Duo, Google Authenticator.

- Aumentar el "nivel de alerta" de la detección, con una mayor supervisión, en particular de las cuentas, dominios o direcciones IP relacionadas. Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
- Considerar la posibilidad de contar con asistencia externa en materia de seguridad para apoyar la investigación y la corrección. Herramientas: Microsoft Authenticator, Duo, Google Authenticator.
- Confirmar las actualizaciones de software y antimalware pertinentes en los activos. Herramientas: Microsoft Authenticator, Duo, Google Authenticator.

Referencia: Recursos de Remediación.

- Recursos financieros: Presupuesto asignado para consultores externos, licencias de software de seguridad y herramientas forenses.
- Recursos de personal: Equipo de TI interno, equipo de seguridad, personal de soporte y, si es necesario, consultores externos de ciberseguridad.
- Recursos logísticos: Acceso a laboratorios de análisis, sistemas de respaldo, herramientas de comunicación seguras y repositorios forenses.

Comunicar

- Herramientas y procedimientos:
 - Sistema de gestión de incidentes (ITSM, ServiceNow, Jira).
 - Correo seguro y canales internos de comunicación (Teams, Slack corporativo).
 - Plantillas de notificación para usuarios, clientes y dirección.
 - Participantes: equipo de seguridad, responsables de TI, dirección, asesoría legal, relaciones públicas si aplica.
1. Elevar el incidente y comunicarlo a la dirección según el procedimiento.
 - *Añadir: Notificar mediante informe ejecutivo resumido, incluyendo impacto preliminar y medidas de contención iniciales.*
 - Herramientas: correo seguro, reuniones de emergencia vía Teams/Zoom.
 2. Documente el incidente según el procedimiento (y [informe](#)):
 - *Añadir: Registrar todos los hallazgos en la herramienta de gestión de incidentes, incluyendo usuarios afectados, sistemas comprometidos, IoC detectados y acciones tomadas.*

3. Comunicarse con los asesores jurídicos internos y externos según el procedimiento, incluyendo discusiones sobre el cumplimiento, la exposición al riesgo, la responsabilidad, el contacto con las fuerzas del orden, *etc.*
 - Añadir: Incluir abogados internos y externos, discutir cumplimiento regulatorio, exposición al riesgo y posible contacto con fuerzas del orden.
4. Comunicación con los usuarios (interna)
 - i. Comunicar las actualizaciones de la respuesta a incidentes según el procedimiento.
 - Actualizaciones periódicas sobre estado del incidente y medidas aplicadas.
 - ii. Comunicar el impacto del incidente **y** las acciones de respuesta al mismo (e.j., contención: "¿Por qué está caído el archivo compartido?")
 - Explicar impacto concreto, por ejemplo, servicios afectados y tiempos estimados de recuperación.
 - iii. Comunicar los requisitos: "¿Qué deben hacer y no hacer los usuarios?"
 - Instrucciones claras sobre acciones que los usuarios deben o no realizar (no abrir correos sospechosos, cambiar contraseñas, reportar actividad).
5. Comunicar a los clientes
 - i. Centrarse especialmente en aquellos cuyos datos se vieron afectados.
 - Priorizar clientes cuyos datos podrían haberse visto comprometidos.
 - ii. Genere las notificaciones requeridas en base a las regulaciones aplicables (particularmente aquellas que puedan considerar el phishing como una violación de datos o que requieren notificaciones de otro tipo).
 - Generar notificaciones basadas en regulaciones aplicables (RGPD, NIS2, leyes *locales de protección de datos*).

6. Contactar con el/los proveedor/es de seguros

- i. Discutir qué recursos pueden poner a disposición, qué herramientas y proveedores apoyan y pagarán, *etc.*
 - o Discutir recursos disponibles, cobertura de herramientas y consultores.
- ii. Cumplir con los requisitos de presentación de informes y reclamaciones para proteger la elegibilidad.
 - o Cumplir con requisitos de presentación de informes y reclamaciones para proteger la elegibilidad de la póliza.

7. Considere la posibilidad de notificar e implicar a [las fuerzas del orden](#).

Aquí abría que vincular los puntos que se muestran con los reales de la organización, como es ficticia los dejo por defecto.

- i. [Aplicación de la ley local](#)
- ii. [Aplicación de la ley a nivel estatal o regional](#)
- iii. [Fuerzas de seguridad europeas o nacionales](#)

8. Comuníquese con los proveedores de seguridad y de TI.

Aquí abría que vincular los puntos que se muestran con los reales de la organización, como es ficticia los dejo por defecto.

- i. Notifique y colabore con [proveedores gestionados](#) para el procedimiento
- ii. Notifique y colabore con [consultores de respuesta ante incidentes](#) para el procedimiento

Recuperación

Pasos de recuperación personalizados para el phishing

- Restaurar los servicios afectados a su estado normal, asegurando integridad y disponibilidad.
- Verificar que no quedan credenciales comprometidas ni accesos no autorizados.
- Revisar configuraciones de seguridad y reforzar políticas de correo, autenticación y acceso.
- Implementar lecciones aprendidas en procedimientos y controles internos.

1. Poner en marcha un plan de continuidad de negocio/recuperación de desastres si el compromiso implica interrupciones de negocio: e.j., considerar la migración a ubicaciones operativas alternativas, clústers de conmutación por error, sistemas de copias de seguridad.
 - Herramientas: sistemas de backup y recuperación (Veeam, Commvault, Acronis), clústers de conmutación por error, entornos alternativos de operación.
 - Procedimiento: activar plan de DR, migrar cargas críticas a ubicaciones de respaldo, validar restauración de servicios y datos.

2. Reforzar los programas de formación sobre los ataques de phishing sospechosos. Los principales indicadores de sospecha pueden ser:
 - Herramientas: plataformas de formación online (KnowBe4, Cofense, SANS Security Awareness).
 - Procedimiento: enviar campañas de concienciación, simulaciones de phishing, pruebas de evaluación periódicas.
 - Contenido clave: errores ortográficos, remitentes sospechosos, enlaces maliciosos, archivos inesperados, correos externos marcados, informar de actividades sospechosas al departamento de TI.
 - errores ortográficos en el mensaje o en el asunto
 - nombres de remitentes que parezcan de teléfono, incluida la falta de coincidencia entre el nombre y la dirección de correo electrónico.
 - direcciones de correo electrónico personales para asuntos oficiales (e.j., correos electrónicos de gmail o yahoo de colegas de trabajo)
 - líneas de asunto marcadas con "[EXTERNO]" en correos electrónicos que parecen internos.
 - [enlaces maliciosos o sospechosos](#)
 - recibir un correo electrónico o un archivo adjunto que no se esperaba, pero que proviene de alguien conocido (contactar con el remitente antes de abrirlo).
 - informar de actividades sospechosas al departamento de TI o de seguridad.

3. Asegúrate de que el personal de TI y de seguridad está al día de las técnicas de phishing más recientes.
 - Herramientas: boletines de ciberseguridad, plataformas de threat intelligence (ThreatConnect, MISP).
 - Procedimiento: formación continua sobre nuevas técnicas de phishing, revisión de informes de incidentes recientes y actualización de defensas.
4. Determine si ha fallado algún control al ser víctima de un ataque y rectifíquelo. He aquí una [buena fuente](#) a tener en cuenta tras un ataque de phishing.
 - Procedimiento: identificar qué controles no funcionaron (antivirus, filtrado de correo, MFA), documentar fallos y aplicar mejoras inmediatas.
 - Herramientas: logs de SIEM (Splunk, QRadar), auditorías de seguridad, análisis de vulnerabilidades.

Recursos

Referencia: Acciones del usuario ante la sospecha de un ataque de phishing

Datos personalizados para los usuarios ante una sospecha de phishing.

- No responder al correo sospechoso ni interactuar con enlaces o adjuntos.
 - No reenviar el mensaje a otros usuarios, salvo siguiendo el procedimiento de reporte.
 - No borrar el correo hasta que el equipo de TI o seguridad lo indique.
 - Si se han introducido credenciales, informar inmediatamente al servicio de ayuda.
 - Seguir en todo momento las instrucciones del equipo de TI o seguridad.
1. Mantenga la calma y respire profundamente.
 2. Haz fotos de tu pantalla con tu smartphone mostrando las cosas que has notado: el mensaje de phishing, el enlace si lo has abierto, la información del remitente.
 3. Toma notas sobre el problema o los problemas utilizando la aplicación de notas de voz de tu smartphone o con papel y boli. ¡Todo por poco que sea, ayuda! Documenta lo siguiente:
 - i. ¿Qué has notado?
 - ii. ¿Por qué pensaste que era un problema?

- iii. ¿Qué estabas haciendo en el momento en que lo detectaste?
 - iv. ¿Cuándo se produjo por primera vez, y con qué frecuencia desde entonces?
 - v. ¿Dónde estaba cuando ocurrió y en qué red? (oficina/casa/tienda, con cable/inalámbrica, con/sin VPN, etc.)
 - vi. ¿Qué sistemas está utilizando? (sistema operativo, nombre de host, etc.)
 - vii. ¿Qué cuenta utilizas?
 - viii. ¿A qué datos suele acceder?
 - ix. ¿Con quién más te has puesto en contacto sobre este incidente y qué les has dicho?
4. Ponte en contacto con el [servicio de ayuda](#) utilizando la [línea directa de phishing](#) o la [barra de herramientas de informe de phishing](#) y sé lo más servicial posible.
- Herramientas: botón “Reportar phishing” del cliente de correo, correo dedicado de seguridad, portal ITSM o teléfono de soporte.
 - Procedimiento: adjuntar el mensaje original o reenviarlo como archivo (.eml / .msg) si se solicita.
5. Ten paciencia: ¡La respuesta puede ser perturbadora, pero estas protegiendo a tu equipo y a la organización! **Gracias.**
- El equipo de seguridad puede solicitar información adicional o pedir que el dispositivo no se apague ni se use temporalmente.

Referencia: Acciones del Help Desk ante la Sospecha de un Ataque Phishing

Pasos personalizados para el personal de servicio de asistencia ante una sospecha phishing.

- No analizar enlaces ni adjuntos fuera de los procedimientos establecidos.
- No descartar el incidente como “falso positivo” sin validación del equipo de seguridad.
- Priorizar el ticket según impacto potencial y número de usuarios afectados.
- Mantener comunicación clara y calmada con el usuario.

1. Mantenga la calma y respire profundamente.
2. Abra un ticket para documentar el incidente, según el procedimiento.
 - **Plantilla del ticket debe incluir:**
 - Usuario afectado y datos de contacto
 - Fecha y hora de detección
 - Medio de detección (usuario, sistema, tercero)
 - Resumen del mensaje sospechoso
 - Acciones realizadas por el usuario
 - Sistemas, cuentas y datos potencialmente afectados
 - **Flujo posterior:**
 - Escalado automático al equipo de seguridad
 - Marcado como incidente de phishing
 - Bloqueo de cierre hasta validación de seguridad
3. Pídale al usuario que tome fotos de su pantalla usando su smartphone mostrando las cosas que notó: el mensaje de phishing, el enlace si lo abrió, la información del remitente, etc. Si es algo que notó directamente, haga lo mismo usted.
4. Toma notas sobre el problema o los problemas utilizando la aplicación de notas de voz de tu smartphone o con papel y boli. Si se trata de un informe de usuario, haz preguntas detalladas, incluyendo:
 - i. ¿Qué has notado?
 - ii. ¿Por qué pensaste que era un problema?
 - iii. ¿Qué estabas haciendo en el momento en que lo detectaste?
 - iv. ¿Cuándo se produjo por primera vez, y con qué frecuencia desde entonces?
 - v. ¿De qué redes se trata? (oficina/casa/tienda, cableada/inalámbrica, con/sin VPN, etc.)
 - vi. ¿De qué sistemas se trata? (sistema operativo, nombre de host, etc.)
 - vii. ¿De qué datos se trata? (rutas, tipos de archivos, archivos compartidos, bases de datos, software, etc.)
 - viii. ¿Qué usuarios y cuentas están implicados? (directorío activo, SaaS, SSO, cuentas de servicio, etc.)
 - ix. ¿A qué datos suelen acceder los usuarios implicados?
 - x. ¿Con quién más te has puesto en contacto sobre este incidente y qué les has dicho?
5. Haz las preguntas de seguimiento que sean necesarias. **Usted es de respuesta ante Incidentes, Contamos contigo.**

6. Obtenga información de contacto detallada del usuario (domicilio, oficina, móvil), si procede.
7. Registra toda la información en el ticket, incluyendo notas manuscritas y de voz.
8. Poner en cuarentena a los usuarios y sistemas afectados.
 - Suspender temporalmente cuentas comprometidas si hay indicios claros.
 - Forzar cambio de credenciales bajo indicación del equipo de seguridad.
 - Aislar equipos afectados de la red si se sospecha ejecución de malware.
 - Automatizar acciones mediante herramientas de ITSM, EDR o scripts aprobados.
9. Póngase en contacto con el [equipo de seguridad](#) y preparase para participar en la respuesta según las indicaciones: investigación, remediación comunicación y recuperación.

Información adicional

1. [Recurso Ataque Anti-Phishing](#)
2. [Métodos de Identificación de Ataques Phishing](#)
3. [Ejemplos Correos electrónicos de Phishing](#)
4. [Mejores prácticas Anti-Phishing](#)

Proceso de revisión, documentación y mejora.

Una vez que la incidencia está resuelta, empieza una fase orientada a asegurarse de que el incidente ha sido completamente solucionado y que se ha recuperado la normalidad. En esta fase se desglosa como cerrar el incidente y documentar lo ocurrido para reducir la probabilidad de futuros incidentes.

Cierre del incidente

El cierre se realiza después de comprobar que la amenaza ha sido eliminada, y que los servicios, sistemas... que han sido afectados ya funcionan con normalidad. En este paso se comprueba que no existen restos del incidente.

Los pasos claves son los siguientes:

- Verificar que la amenaza ha sido completamente eliminada.
- Comprobar que todo funciona con normalidad
- Tomar notas de todo lo sucedido para prevenir en el futuro.

Documentación asociada

En este punto se registra toda la información relacionada con el incidente, se hará de forma clara y ordenada. Incluye un informe final explicando todo el incidente. Esta documentación servirá como referencia si fuese necesario. Los pasos clave son los siguientes:

- Informe final del incidente.
- Recopilar todas las evidencias.
- Documentar todas las acciones que se han ejecutado.

Aprendizaje adquirido

Después de cerrar el incidente, se debe analizar todo lo ocurrido, para entender que ha pasado, en que se falló y en que se acertó. En este punto se pretende detectar nuestras debilidades y valorar la eficacia de todos los controles de seguridad, la coordinación de los equipos... Los pasos clave son los siguientes:

- Identificación de fallos, tanto técnicos como de comunicación...
- Evaluar la eficacia y la respuesta de los controles implantados.
- Tener un registro de todo lo aprendido, tanto lo malo como las buenas prácticas.

Proceso de mejora

Con todo el trabajo hecho ahora se aplican las acciones necesarias para mejorar y reforzar la seguridad. Estas acciones incluyen varios procedimientos que tienen el objetivo de reducir la posibilidad de futuros incidentes. Estas acciones entre otras son:

- Actualización de procedimientos y del plan de actuación ante incidentes.
- Refuerzo de medidas de seguridad técnicas y organizativas.
- Formación y concienciación del personal implicado.

Traslado de información

En el traslado de información a las personas o entidades, se comunicará el cierre y toda la información relacionada con el incidente. Esta información será remitida a la **dirección de la empresa y a todo el personal afectado**. En caso de que debido a la incidencia la normativa lo exija, también habrá que informar a otras partes afectadas como clientes, autoridades... Para garantizar la transparencia y cumplir la ley. Los puntos clave de este traslado de información sería el siguiente.

- Informar a la dirección de la empresa sobre el incidente y de las medidas que se ha tomado.
- Informar del cierre del incidente a clientes, además de las medidas que se han tomado.
- Informar a las autoridades si lo exige la ley.

NOTAS:

- Para la parte del Playbook, me he basado en el documento que se adjunta en la tarea como información, este en particular:
<https://github.com/jmarrieta98/plantilla-de-respuesta-a-incidentes/blob/main/playbooks/playbook-phishing.md>

Y en todas las partes que ponía TODO es donde he agregado la información faltante.

Webgrafía:

- <https://www.ismsforum.es/ficheros/descargas/protocolo-de-actuacion-frente-a-incidente-en.pdf>
- <https://www.sentinelone.com/es/cybersecurity-101/services/incident-response-plan-2/>
- <https://dspace.ups.edu.ec/bitstream/123456789/29344/1/UPS-CT011844.pdf>
- <https://github.com/jmarrieta98/plantilla-de-respuesta-a-incidentes/blob/main/examples/plan.md>
- <https://github.com/jmarrieta98/plantilla-de-respuesta-a-incidentes/blob/main/playbooks/playbook-phishing.md>